CAHIER DES CHARGES

Application Web

Moul I Hanout

Document	Cahier des Charges — Application web Moul I Hanout
Version	v1.0 — Draft
Date	Mars 2026
Statut	En cours de validation
Périmètre	MVP web (P0) + feuille de route P1/P2
Public cible	Gérant (Owner) + Caissier(s)

Table des Matières

Table des Matières 2
1. Synthèse Exécutive 3
2. Contexte et Objectifs du Produit 3
2.1 Objectifs métier 3
2.2 Objectifs qualité 4
3. Périmètre Fonctionnel 5
3.1 Tableau de périmètre détaillé 5
3.2 Règles métier principales 6
4. Parcours Utilisateurs 7
4.1 Parcours principal — Vente (POS Web) 7
4.2 Autres parcours clés 7
5. Rôles et Permissions (RBAC) 8
5.1 Définition des rôles 8
6. Architecture Technique 9
6.1 Vue en couches 9
6.2 Composants techniques 9
6.3 Hébergement — Options comparées 10
7. Modèle de Données 11
7.1 Dictionnaire de données 11
8. Exigences Non Fonctionnelles 12
8.1 Performance — Core Web Vitals 12
8.2 Sécurité — OWASP ASVS 12
8.3 Accessibilité — WCAG 2.2 AA 13
9. Stratégie de Tests et Critères d'Acceptation 14
9.1 Pyramide de tests 14
9.2 Critères d'acceptation P0 14
10. Planning et Jalons 15
10.1 Détail des phases 15
11. Estimation Budgétaire 16
12. Registre des Risques 17
13. Glossaire 18
14. Références Officielles 18

1. Synthèse Exécutive

Moul I Hanout est une application web de gestion opérationnelle dédiée aux commerces de proximité (hanout). Elle digitalise les opérations quotidiennes en regroupant en un seul outil la vente, la gestion des stocks, le catalogue produits et le pilotage de l'activité.

Figure 1 — Objectifs métier et indicateurs de succès

Points à confirmer lors du cadrage initial

- Public cible exact : gérant seul, avec caissier(s), ou déploiement multi-boutiques ?
- Budget maximal alloué au projet
- Cadre légal : Maroc (CNDP) ou Union Européenne (RGPD) ?
- Contraintes techniques : hébergeur imposé, intégrations existantes ?

2. Contexte et Objectifs du Produit

2.1 Objectifs métier

Le projet vise trois résultats mesurables, directement liés à la rentabilité et à la fiabilité opérationnelle du commerce :

- Accélération de la vente : réduire le temps moyen de transaction (TMT) et le nombre d'erreurs de caisse (retours, annulations).
- Fiabilisation du stock : éliminer les écarts entre stock théorique et réel ; alertes proactives sur les ruptures.
- Pilotage simplifié : permettre au gérant de consulter CA, transactions, top produits et marges sans formation avancée.

2.2 Objectifs qualité

Axe qualité	Référentiel	Cible
Performance	Core Web Vitals (web.dev)	LCP ≤ 2,5s / INP ≤ 200ms / CLS ≤ 0,1
Sécurité	OWASP ASVS	Niveau 2 (applications pro)
Accessibilité	WCAG 2.2	Niveau AA
Compatibilité	Navigateurs modernes	Chrome, Firefox, Edge, Safari (2 dern. versions)

3. Périmètre Fonctionnel

Définition des niveaux de priorité

P0 — MVP Indispensable au lancement. Tout P0 doit être livré avant la mise en production.
P1 — Post-MVP Améliore fortement la solution ; peut être livré en sprint suivant le MVP.
P2 — Évolution Extensions selon budget et retours terrain. Non bloquant.

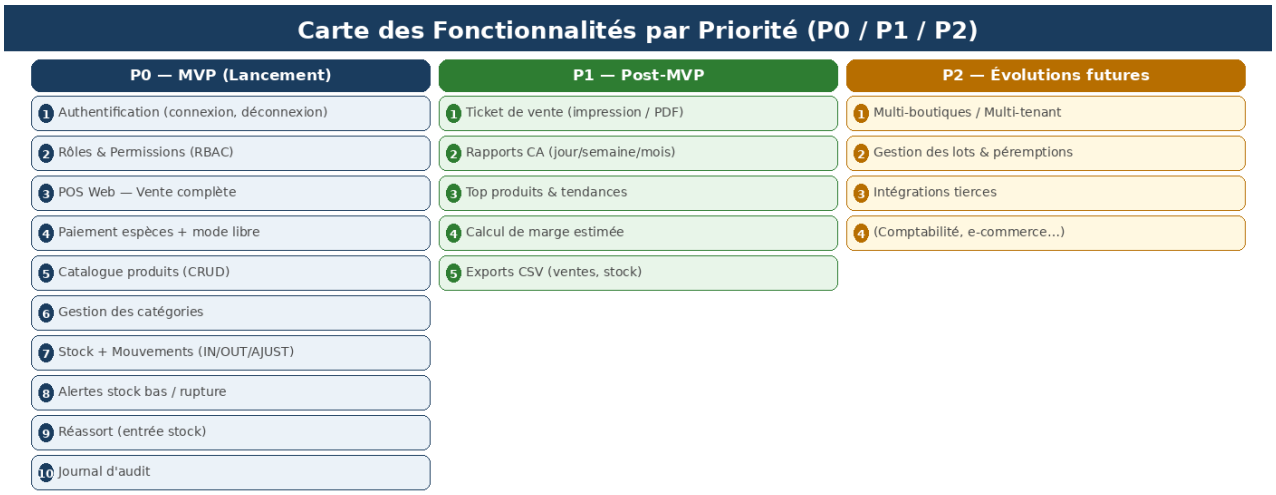

Figure 2 — Carte des fonctionnalités par priorité

3.1 Tableau de périmètre détaillé

Domaine	Fonctionnalités	Priorité
Authentification	Connexion, déconnexion, réinitialisation du mot de passe	**P0**
Rôles & Permissions	RBAC Owner / Caissier — restriction des actions sensibles	**P0**
POS Web (Vente)	Recherche produit, ajout panier, quantités, remise simple, validation	**P0**
Paiement	Espèces (rendu monnaie) + mode libre (libellé personnalisé)	**P0**
Catalogue produits	CRUD : nom, catégorie, code-barres, prix de vente, photo optionnelle	**P0**
Catégories	CRUD des catégories de produits	**P0**
Gestion du stock	Stock par produit + mouvements IN / OUT / AJUSTEMENT	**P0**
Alertes de stock	Seuil bas / rupture + liste d'actions correctives	**P0**
Réassort	Entrée de stock avec coût optionnel et historique	**P0**

Journal d'audit	Traçabilité des actions sensibles (append-only)	**P0**
Ticket de vente	Affichage + impression navigateur / export PDF	**P1**
Rapports	CA jour / semaine / mois, top produits, tendances	**P1**
Marges	Marge estimée si prix d'achat renseigné	**P1**
Exports	CSV ventes, stock, produits	**P1**
Multi-boutiques	Plusieurs points de vente / multi-tenant	**P2**
Gestion des lots	Lots, dates de péremption, liste d'expiration proche	**P2**
Intégrations tierces	Comptabilité, e-commerce, etc.	**P2**

3.2 Règles métier principales

- Vente : toute vente validée crée une transaction et ses lignes, décrémente le stock et consigne l'opération dans le journal d'audit (transaction atomique).
- Stock : tout changement de stock passe obligatoirement par un mouvement enregistré (traçabilité complète, aucune modification directe sans audit).
- Permissions : la modification des prix, la gestion du stock, les exports et la gestion des utilisateurs sont réservés au rôle Owner.
- Cohérence : toutes les opérations critiques (vente, stock) s'exécutent dans une transaction DB ACID.

4. Parcours Utilisateurs

4.1 Parcours principal — Vente (POS Web)

Le parcours de vente est le flux le plus critique de l'application. Il doit être exécutable en moins de 30 secondes pour un panier standard.

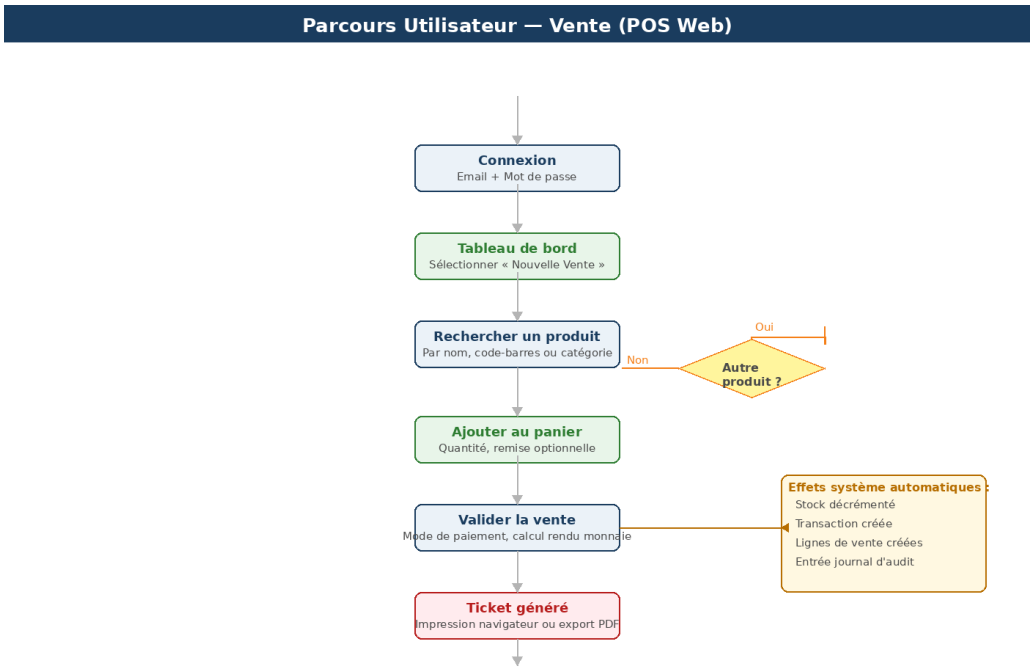

Figure 3 — Diagramme de flux : Parcours de vente POS Web

4.2 Autres parcours clés

Parcours	Étapes principales	Acteur
Réassort stock	Sélectionner produit → Saisir quantité + coût → Valider → Stock mis à jour + mouvement créé	Owner
Ajouter un produit	Catalogue → Nouveau produit → Remplir fiche → Enregistrer → Disponible en caisse	Owner
Consulter rapports	Tableau de bord → Rapports → Sélectionner période → Visualiser CA + top produits	Owner
Gérer utilisateurs	Paramètres → Utilisateurs → Ajouter / Modifier rôle → Sauvegarder	Owner
Traiter une alerte stock	Notifications → Voir produits en rupture → Déclencher réassort ou ajustement	Owner

5. Rôles et Permissions (RBAC)

Le contrôle d'accès est basé sur les rôles (Role-Based Access Control). Deux rôles sont définis pour le MVP. Toutes les vérifications de permissions s'effectuent exclusivement côté serveur.

Matrice des Rôles et Permissions (RBAC)

Action	Caissier	Owner / Gérant
Connexion / Déconnexion	✓	✓
Vente — POS Web	✓	✓
Consulter le catalogue	✓	✓
Modifier produits / prix	✗	✓
Gérer les catégories	✗	✓
Consulter le stock	✓	✓
Entrée de stock (réassort)	✗	✓
Ajustement manuel du stock	✗	✓
Consulter les rapports	✗	✓
Exporter les données (CSV)	✓	✓
Gérer les utilisateurs	✗	✓
Consulter le journal d'audit	✗	✓
Configuration boutique	✗	✓

Légende : ✓ Autorisé ✗ Non autorisé

Figure 4 — Matrice des rôles et permissions

5.1 Définition des rôles

Rôle	Responsabilités	Restrictions
Owner / Gérant	Accès complet à toutes les fonctions. Gère l'équipe, les prix, les rapports et la configuration.	Responsable de la conformité et de la sécurité des données.
Caissier	Effectue les ventes, consulte le catalogue et le stock. Peut exporter les données.	Ne peut pas modifier les prix, gérer le stock en profondeur ni accéder aux rapports ou aux utilisateurs.

6. Architecture Technique

6.1 Vue en couches

L'architecture suit un modèle en couches clairement séparées, favorisant la maintenabilité, la testabilité et la scalabilité horizontale.

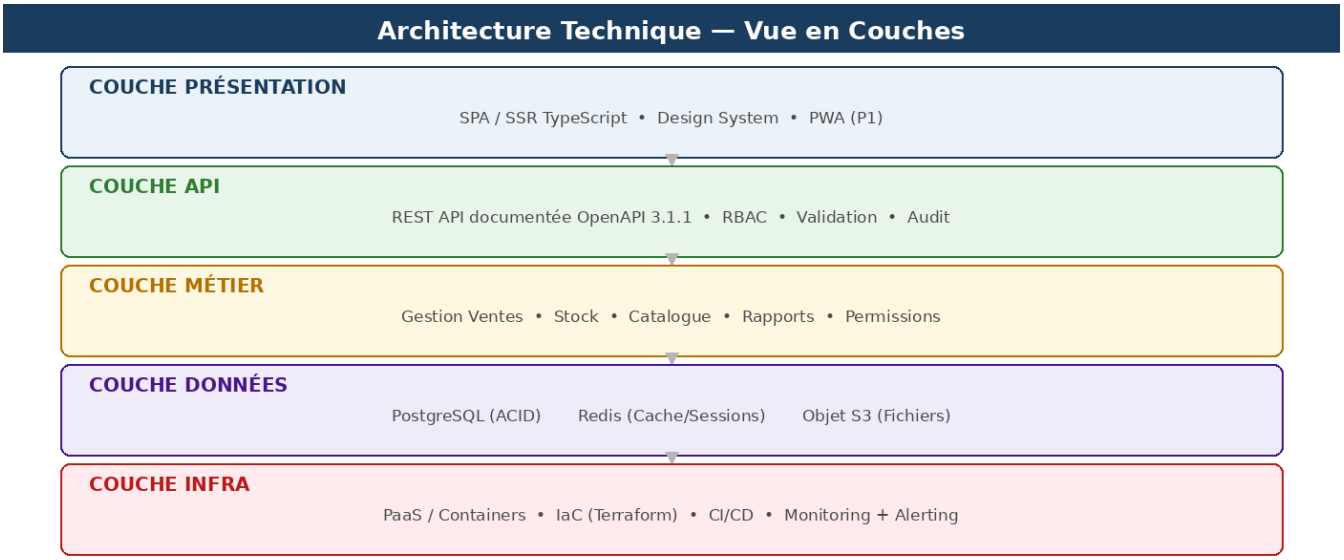

Figure 5 — Architecture technique vue en couches

6.2 Composants techniques

Couche	Technologie recommandée	Justification
Frontend	React	Performances, SEO possible, expérience utilisateur fluide
Backend API	REST + OpenAPI 3.1.1	Contrat d'API clair, documentation automatique, testabilité
Base de données	PostgreSQL	Transactions ACID, cohérence forte, JSON natif
Cache	Redis	Sessions sécurisées, rate-limiting, cache applicatif
Stockage fichiers	S3-compatible	Photos produits, exports CSV, tickets PDF
Observabilité	Logs structurés + métriques	Debugging, alerting, SLA monitoring
CI/CD	Pipeline automatisé	Tests, build, déploiement reproductible
IaC	Terraform / Pulumi	Infrastructure versionnée, reproductible

6.3 Hébergement — Options comparées

Option	Time-to-market	Coût	Recommandé si
PaaS / Containers managés	Rapide	Moyen	MVP et croissance initiale
Kubernetes managé	Moyen	Moyen-élevé	Multi-tenant, fort volume
VPS + containers	Lent	Faible	Budget très contraint, équipe DevOps

7. Modèle de Données

Le noyau de données P0 est conçu pour garantir la cohérence transactionnelle et la traçabilité complète de toutes les opérations.

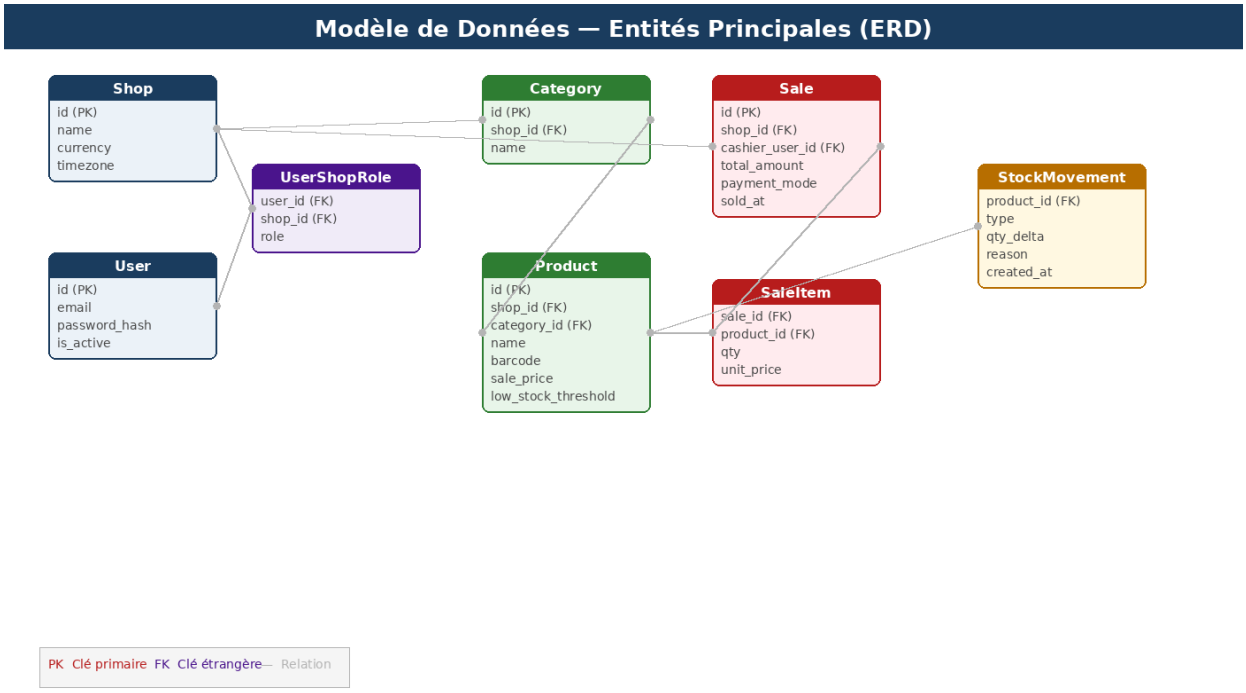

Figure 6 — Diagramme Entité-Relation (ERD) — Noyau P0

7.1 Dictionnaire de données

Entité	Rôle	Champs clés
Shop	Boutique / tenant	id (PK), name, currency, timezone
User	Compte utilisateur	id (PK), email, password_hash, is_active, created_at
UserShopRole	RBAC	user_id (FK), shop_id (FK), role (OWNER | CASHIER)
Category	Classification	id (PK), shop_id (FK), name, created_at
Product	Produit du catalogue	id (PK), shop_id (FK), category_id (FK), name, barcode, sale_price, cost_price?, low_stock_threshold
Sale	Vente	id (PK), shop_id (FK), cashier_user_id (FK), total_amount, payment_mode, sold_at
SaleItem	Lignes de vente	sale_id (FK), product_id (FK), qty, unit_price, discount?
StockMovement	Traçabilité stock	id (PK), product_id (FK), type (IN|OUT|ADJUST), qty_delta, reason, created_by (FK), created_at
AuditLog	Journal d'audit	id (PK), shop_id (FK), user_id (FK), action, entity_type, entity_id, payload, created_at

8. Exigences Non Fonctionnelles

8.1 Performance — Core Web Vitals

Indicateur	Cible « Bon »	Seuil max.	Mesure
LCP — Largest Contentful Paint	**≤ 2,5 s**	< 4,0 s	75e percentile, mobile + desktop
INP — Interaction to Next Paint	**≤ 200 ms**	< 500 ms	75e percentile
CLS — Cumulative Layout Shift	**≤ 0,1**	< 0,25	75e percentile

Optimisations obligatoires : CDN pour les assets statiques, compression Brotli/Gzip, cache HTTP, lazy loading des images, code-splitting, pas de JavaScript bloquant critique.

8.2 Sécurité — OWASP ASVS

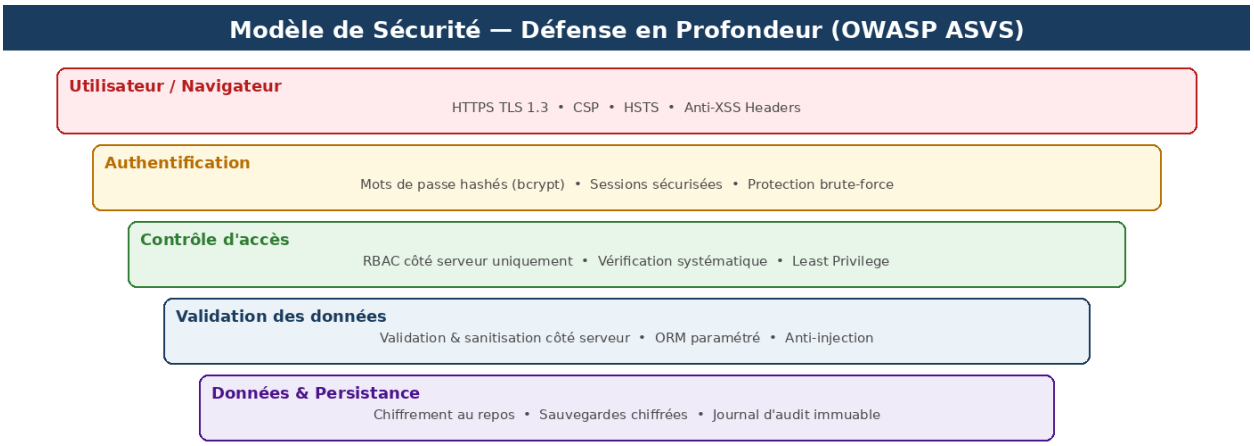

Figure 7 — Modèle de sécurité : défense en profondeur

Domaine sécurité	Exigences (testables)
Contrôle d'accès	Vérification RBAC côté serveur sur chaque endpoint. Aucune permission client-side uniquement.
Authentification	Mots de passe hashés (bcrypt/argon2). Protection brute-force. Expiration et rotation des sessions.
Validation des données	Validation et sanitisation systématique des entrées. ORM paramétré (anti-injection SQL).
Headers & Transport	HTTPS obligatoire, TLS 1.3, CSP, HSTS, X-Frame-Options, X-Content-Type-Options.
Audit & Logging	Journal d'audit immuable (append-only). Logs d'accès et d'erreurs structurés.
Secrets	Secrets gérés via vault ou variables d'environnement sécurisées. Jamais en clair dans le code.

8.3 Accessibilité — WCAG 2.2 AA

- Navigation clavier complète : tab order logique, focus visible, pas de piège clavier.
- Labels explicites sur tous les champs de formulaire ; messages d'erreur accessibles.
- Contraste minimum 4,5:1 pour le texte normal, 3:1 pour les grands textes.
- Composants réutilisables accessibles par défaut (design system).
- Audit RGAA si déploiement en contexte réglementaire français.

9. Stratégie de Tests et Critères d'Acceptation

9.1 Pyramide de tests

Type de test	Couverture	Exemples
Tests unitaires	Fonctions métier isolées	Calcul rendu monnaie, seuils stock, totaux, remises
Tests d'intégration	API + Base de données	Vente → lignes → mouvements stock → audit
Tests E2E	Scénarios complets	Vendre, réassort, gérer produit, droits RBAC
Tests de sécurité	OWASP ASVS check-list	Auth, session, authz, validation des entrées, logs
Tests accessibilité	WCAG 2.2 / RGAA	Axe, Lighthouse, tests manuels clavier
Tests de performance	Budgets Core Web Vitals	LCP/INP/CLS en CI + RUM en production

9.2 Critères d'acceptation P0

User Story	Critère d'acceptation	Preuve attendue
Valider une vente	La vente décrémente le stock ET crée une entrée dans le journal d'audit (transaction atomique).	Test intégration + E2E vert
Contrôle des droits	Un caissier ne peut pas modifier les prix via l'API, même avec un appel direct.	Test E2E + test authz serveur
Traçabilité stock	Toute modification de stock crée un mouvement en base — aucune exception.	Test intégration DB
Alerte stock bas	Quand le stock passe sous le seuil, l'alerte s'affiche dans l'interface.	Test E2E + test unitaire
Performance POS	Le POS respecte LCP ≤ 2,5s et INP ≤ 200ms en conditions réelles.	Rapport CI + RUM
Accessibilité	Aucune erreur Axe critique sur les écrans principaux.	Rapport Lighthouse + Axe

10. Planning et Jalons

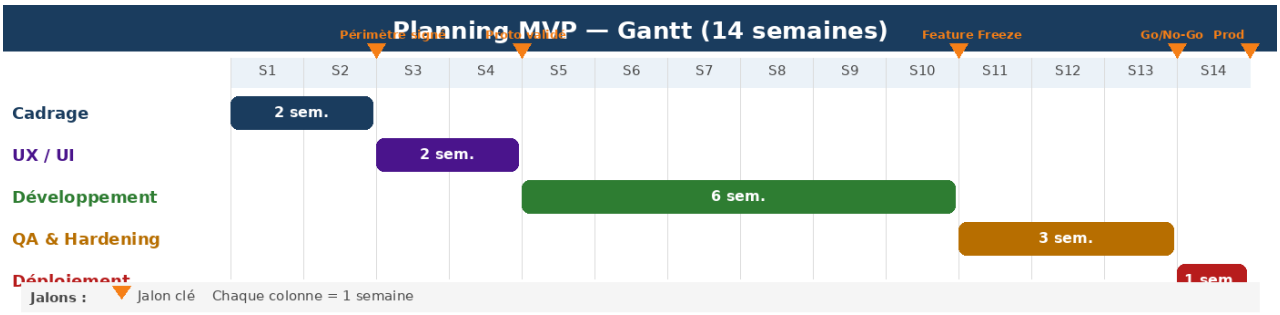

Figure 8 — Planning MVP — Gantt (14 semaines indicatives)

10.1 Détail des phases

Phase	Durée	Jalon	Livrables
Cadrage	2 sem.	Périmètre MVP signé	Backlog P0/P1/P2 priorisé, risques identifiés, critères d'acceptation validés
UX / UI	2 sem.	Prototype validé	Wireframes low-fi, maquettes hi-fi, design system, guide de composants
Développement	6 sem.	Feature freeze	Front + API + DB + RBAC + audit — tous les P0 livrés
QA & Hardening	3 sem.	Go / No-Go	Campagne de tests complète : fonctionnel, sécurité, accessibilité, performance
Déploiement	1 sem.	Mise en production	Runbook opérationnel, monitoring actif, sauvegardes configurées, SLA activé

Hypothèse de durée

Le planning est établi pour une équipe de 3 à 5 personnes (1 PO, 1 UX, 2 devs, 1 QA).
Les durées sont indicatives et doivent être ajustées selon la composition et la disponibilité de l'équipe.

11. Estimation Budgétaire

En l'absence d'un budget maximal défini, trois scénarios sont proposés. Les charges sont exprimées en jours.hommes (j/h). Les coûts sont à calculer en appliquant le TJM local.

Poste	Lean — MVP strict	Standard (recommandé)	Robuste — Qualité+
Product / BA	10 – 15 j/h	**15 – 25 j/h**	25 – 40 j/h
UX / UI	10 – 15 j/h	**15 – 30 j/h**	30 – 45 j/h
Développement Front	30 – 40 j/h	**45 – 60 j/h**	60 – 90 j/h
Développement Backend	30 – 40 j/h	**45 – 70 j/h**	70 – 110 j/h
QA	10 – 15 j/h	**20 – 35 j/h**	35 – 60 j/h
DevOps / IaC	5 – 8 j/h	**8 – 15 j/h**	15 – 30 j/h
Infra mensuelle	Faible	**Faible → Moyen**	Moyen
Licences / outils	Faible	**Faible → Moyen**	Moyen

Le scénario Standard est recommandé pour un premier déploiement production avec des standards de qualité professionnels.

12. Registre des Risques

Risque	Prob.	Impact	Plan de mitigation
Périmètre trop large (scope creep)	M	**Élevé**	Figer P0 dès le cadrage. Mettre en place un processus de change control avec validation Owner.
Bugs critiques sur le stock	M	**Élevé**	Transactions ACID côté DB. Tests d'intégration obligatoires. Audit applicatif.
Failles d'autorisation (RBAC)	M	**Élevé**	OWASP ASVS. Tests authz systématiques sur chaque endpoint API.
Performance insuffisante	M	**Moyen**	Budgets de performance définis dès le design. Mesures LCP/INP/CLS en CI.
Non-conformité accessibilité	M	**Moyen**	Audits WCAG en CI (Axe). Tests manuels sur les écrans principaux.
Flou légal / localisation	M	**Élevé**	Cadrage conformité CNDP (Maroc) ou RGPD (UE). Minimisation des données collectées.
Défaillance infra en heures d'ouverture	F	**Élevé**	Monitoring 24/7. SLA 99,5% min. Plan de reprise activité documenté.
Dépassement de budget	M	**Moyen**	Estimation par scénarios. Revue budgétaire à mi-développement.

Légende probabilité : F = Faible / M = Moyenne / E = Élevée

13. Glossaire

Terme	Définition
POS Web	Point of Sale Web : interface web de caisse permettant d'effectuer des ventes.
RBAC	Role-Based Access Control : contrôle d'accès basé sur les rôles.
MVP	Minimum Viable Product : version minimale du produit livrable en production.
ACID	Atomicité, Cohérence, Isolation, Durabilité : propriétés des transactions DB.
TMT	Temps Moyen de Transaction : durée moyenne d'une opération de vente.
LCP	Largest Contentful Paint : mesure du temps de chargement du contenu principal.
INP	Interaction to Next Paint : mesure de la réactivité aux interactions utilisateur.
CLS	Cumulative Layout Shift : mesure de la stabilité visuelle de la page.
ASVS	Application Security Verification Standard (OWASP) : référentiel de sécurité.
WCAG	Web Content Accessibility Guidelines : référentiel d'accessibilité web.
CNDP	Commission Nationale de protection des Données Personnelles (Maroc).
RGPD	Règlement Général sur la Protection des Données (Union Européenne).
IaC	Infrastructure as Code : gestion de l'infrastructure via du code versionnable.
SLA	Service Level Agreement : engagement contractuel sur les niveaux de service.

14. Références Officielles

Référentiel	URL
Core Web Vitals — seuils LCP / INP / CLS	https://web.dev/articles/vitals
OWASP ASVS — Application Security	https://owasp.org/www-project-application-security-verification-standard/
OWASP MASVS — Mobile Security	https://mas.owasp.org/MASVS/
WCAG 2.2 — W3C Recommendation	https://www.w3.org/TR/WCAG22/
RGAA — Accessibilité numérique (France)	https://accessibilite.numerique.gouv.fr/

OpenAPI Specification 3.1.1	https://spec.openapis.org/oas/v3.1.1.html
NIST SP 800-218 — SSDF	https://csrc.nist.gov/pubs/sp/800/218/final
CNDP — Protection données (Maroc)	https://www.cndp.ma/